# Protecting SaaS behaviour from REA-assisted reconstruction

REA War Games | Current evidence edition | 19 October 2026

## What the evidence supports

Server-enforced permission and workflow checks can hard-block named unauthorised requests. Keeping implementation on the server closes direct code disclosure. Neither measure automatically prevents an entitled customer from inferring behaviour from permitted answers. To reduce that inference, a product must limit the information, precision or range of behaviours it exposes, then measure the remaining reconstruction accuracy and the customer cost.

On six hidden synthetic pricing targets, the fresh REA-assisted agents achieved 99.3% exact accuracy and 100.0% accuracy within 5% with unrestricted exact totals. The largest mean reduction in within-5% accuracy was 75.6 percentage points for **Only two approved quotes**, leaving 24.4% within-5% accuracy. This is a measured result for one agent attempt per target and policy, not a universal ranking or a whole-SaaS cloning rate.

There is no evidence here of a universal switch that prevents REA or a comparable browser/API client from recreating a SaaS product. The strongest architectural boundary demonstrated is to withhold sensitive arbitrary outputs under server-owned authorisation consistently across workflows. Its value is conditional on what customers may obtain, and it changes the product when general estimation is removed.

## Current effectiveness scorecard

| Defence | Exact accuracy | Within 5% accuracy | Exact reduction (pp) | Within 5% reduction (pp) |
|---|---|---|---|---|
| Exact minimal totals | 99.3% | 100.0% | 0.0 | 0.0 |
| Eight distinct quantities | 93.6% | 95.6% | +5.7 | +4.4 |
| Round estimates to GBP 1,000 | 8.3% | 65.0% | +91.0 | +35.0 |
| Four catalogue quantities | 15.5% | 49.4% | +83.8 | +50.6 |
| Rounded + two exact approvals | 11.8% | 77.1% | +87.4 | +22.9 |
| Only two approved quotes | 11.8% | 24.4% | +87.4 | +75.6 |

Accuracy is the proportion of 256 unseen integer quantities per target whose predicted underlying price matches the reference price exactly, or within the stated relative tolerance. Every policy is scored on the same held-out inputs for that target. A reduction is baseline accuracy minus defended accuracy, expressed in percentage points. Higher positive reduction means less accurate reconstruction; a negative value means the defended run scored better. Exact accuracy counts even a one-cent error as wrong. Within-5% accuracy helps expose useful approximations that an exact-only score would conceal.

**The restricted-product caveat matters.** Catalogue and approval policies remove arbitrary quantities from the supported customer workflow. This benchmark still asks the agent to reconstruct the original private rule across quantities 1 to 1000. A low score there does not mean the remaining product is hard to copy: the four catalogue outputs or two approved outputs can be memorised. General estimation is unavailable under approved-only access. The measurements establish reduced knowledge of withheld behaviour, not prevention of cloning every behaviour that is still offered.

In this run, the eight-quantity cap left 95.6% of unseen prices within 5% of truth. Rounding reduced exact matches to 8.3%, yet left 65.0% within 5%. Rounded estimates plus two exact approvals reached 77.1% within 5%; combined disclosure needs measurement too. Approved-only access returned 42 refusals and 12 permitted quote results across its six agents. These are observed outcomes, not guarantees for other products or longer budgets.

The full agent report includes ranges, every paired result, query use, utility errors and links to each evidence class. The original 18 October paper and the later reconstruction and workflow reports remain historical records; this edition brings their conclusions together with the actual-agent benchmark.

## What REA is doing

REA is Reverse Engineer Anything, a collection of inspection and reverse-engineering tools. Here, the agent chooses quantity, workflow, session and its next probe. The harness turns that choice into UI actions in a fresh Chrome session. REA 6.7.0 runs capture-browser-scenario, fills the input, selects the workflow, clicks Calculate, waits for the result and retains DOM and network artifacts. The wrapper returns observations derived from those retained artifacts. Inspection also returns the delivered page and JavaScript, checked against capture bytes. The LLM compares examples, adapts its probes and writes a JSON price predictor. The evaluator executes no agent-authored program; it evaluates only validated numeric coefficients after the agent is finished. This is actual agent-assisted use of REA, with a deliberately bounded tool interface, not an unconstrained test of every upstream REA agent workflow.

More broadly, an entitled observer can inspect delivered HTML and JavaScript, read API shapes and returned data, inspect declared source maps, analyse retained scripts and sample feature behaviour. REA can expose these representations to an agent. It does not make private server source appear merely because a customer can use a web page. Equivalent behaviour can nevertheless be inferred without recovering the original implementation. Version-pinned implementation references explain the measured operations and their limitations.

## Evidence accumulated in the lab

The original study completed 56 REA operations and 23 application tests. Removing private calculation from the delivered script and reducing the response from nine fields / 370 bytes to three fields / 80 bytes preserved the same legitimate quote. Partial fixes failed: removing maps left the formula in JavaScript; server-only calculation still leaked bands in the API; minimal responses still left the formula in client code. These are observed disclosure changes, not a reconstruction-accuracy score.

The session lab rejected missing, forged and revoked sessions, cross-tenant reads, disallowed actions, client-supplied authority fields and tested request-integrity violations. Normal permitted requests succeeded. The original v1 public demo credential was a demonstrated weakness and remains clearly labelled. The separate v2 teaching fixture uses server-held sessions; it is still not production identity infrastructure. Named hard-block criteria.

The earlier custom learner, told the three-band rule family, reconstructed all held-out prices on 16 targets with 24 exact observations. It remained highly accurate with fewer observations or rounded outputs. This does not measure the new agent: that experiment used a pre-written fitting algorithm and a stronger family prior. Its approved-only follow-up was exploratory and reused holdouts. Earlier reconstruction findings.

The workflow study added six REA captures, 12,000 enumerated refusals, 60 exact normal checks and 88 boundary checks. Quotes, exports and jobs shared server-owned approvals. A deliberately leaky export and self-service approval each restored a protected price. Two constructed private rules agreed on allowed payloads but disagreed on 100 of 1,000 inputs. Under an equal two-world prior and no other clues, exact prediction on that disputed region cannot exceed 50% on average. A labelled arithmetic check also separated their 5%-tolerance intervals. This conditional identifiability argument is not an empirical agent accuracy score; timing, headers and other unobserved channels were excluded. Boundary findings.

The new run contains **224 REA operations**, **727 verified business response rows**, **1902 checked captured-body digests**, **9,216 held-out predictions** and **36,000 secondary full-domain predictions**. There are 36/36 valid predictors and 0 failed or invalid predictors. Failed predictors, if present, score zero in the primary aggregate. All retained coverage states are reported by the verifier: incomplete 224. Incomplete capture is not silently upgraded to complete coverage. Including the earlier 74 REA operations, the repository now contains 298 measured operations; the 49 application/scoring tests are a separate evidence category.

## How the stronger benchmark was run

The prospective plan, prompt, agent harness, tool wrapper, target generator and scorer were hashed before scored targets were generated. Targets were committed by hash and kept outside agent context. Thirty-six fresh ephemeral agents used gpt-6-astra with high reasoning effort, with at most three concurrent cells. Every agent had up to 24 attempted business requests, including denials, 12 REA operations and 20 minutes. It could choose either of two sessions in the same tenant, or the estimate, alias or approved workflow. No operator supplied fitting hints or custom fitted model. After all predictors were saved and hashed, 256 common holdouts per target were randomly selected from quantities never successfully observed by any of its six agents. Target parameters were then published for verification. The secondary full-domain score includes observed quantities and must not be presented as held-out accuracy.

The six targets cover three small rule families, with two targets per family and only one agent attempt per cell. There is no independent human white team, independent replication, production workload, repeated-agent variance estimate or statistical certainty about a wider product population. The agent did not receive the target family, parameters, earlier answers or source repository. It did receive the price domain, a piecewise-polynomial output format and bounded study tools. The format can represent all targets but constrains reconstructions. Built-in model knowledge and arithmetic capability remain relevant. Randomised cell order and paired targets help comparison; they do not isolate every stochastic effect of an LLM. No selected reruns were used to improve results. The recorded model identifier is not an independently pinned set of model weights; service updates can affect future replications.

## Customer cost of reducing disclosure

| Defence | Supported quotes successful | Mean absolute price error | Largest price error |
|---|---|---|---|
| Exact minimal totals | 12/12 | GBP 0.0 | GBP 0.0 |
| Eight distinct quantities | 12/12 | GBP 0.0 | GBP 0.0 |
| Round estimates to GBP 1,000 | 12/12 | GBP 268.3 | GBP 495.6 |
| Four catalogue quantities | 12/12 | GBP 0.0 | GBP 0.0 |
| Rounded + two exact approvals | 12/12 | GBP 0.0 | GBP 0.0 |
| Only two approved quotes | 12/12 | GBP 0.0 | GBP 0.0 |

The tested quotes use quantities 50 and 200. Approved workflows return exact prices there. Rounding can return a successful response with a material price error. Catalogue and approval restrictions reduce the supported input space. The GBP 1,000 rounding step has different relative effects at different price levels and is not a universal recommended setting. No whole-product usability score was measured. Product teams must decide whether a less revealing workflow still supplies the customer outcome they intend to sell.

## What developers should do

- Keep private calculations and credentials out of delivered assets. Treat source-map removal as one delivery check, not as protection for code still shipped to clients.

- Define minimal request and response schemas. Calculate authoritative totals and ownership on the server. Reject client-supplied tenant, price, role or approval authority.

- Apply identity, object, action and current-approval checks to every path that reveals the output, including aliases, exports, jobs and event reads. A convenient secondary route can undo the main control.

- Preserve successful normal tests beside denied cases. Reproduce missing/forged/revoked identity, wrong-tenant access, forbidden fields and altered workflows. Re-score held-out predictions after changing disclosure.

These recommendations follow observed fixture disclosures and denials. The demonstration code uses loopback HTTP and in-memory state and is not a deployment template.

## What architects should do

- Decide which behaviours may be public, customer-visible, role-limited or withheld. A private source file and a private behaviour are different objectives.

- Design one consistent authorisation boundary across synchronous and asynchronous paths. Recheck current authority when a result is read; do not rely only on permission at job creation.

- Treat approval creation as a protected capability. If a customer can approve any chosen input, the general output oracle returns. Model alternate accounts, service identities, caches and exports explicitly.

- Aggregate quotas across equivalent paths and identities as required by the threat model. The fixture checks two sessions in one tenant; it does not prove durable atomic enforcement across production replicas or colluding tenants.

- Commission product-specific review of maintained identity, TLS, policy consistency, revocation, dependency failures and observable side channels. These production properties remain outside the measured lab.

## What product managers should decide and measure

- Specify the value customers need and the private behaviour the business is trying to protect. Avoid a promise of arbitrary exact outputs while assuming those outputs cannot teach an observer.

- Compare the complete trade-off: held-out reconstruction accuracy, precision of legitimate results, supported tasks, false denials, time to complete a task and support demand.

- If appropriate, replace a general sensitive calculator with an approved transaction or a limited catalogue. Customers can still reproduce outputs they are allowed to see; the benefit is withholding additional behaviour.

- Define an acceptable imitation threshold before testing. Exact match, a 1% or 5% tolerance and allowed query/time budgets answer different business questions. No numerical threshold is a universal SaaS security standard.

## Practical acceptance process

1. List sensitive outputs and every customer-accessible route that can disclose them.

2. Establish an exact-output baseline and freeze the evaluation criteria and query budget.

3. Test each control on fresh paired targets. Give a fresh agent only the entitled surface, not the private rule or repository.

4. Freeze the agent's reconstruction before selecting or revealing holdouts. Keep unsuccessful runs and negative reductions.

5. Report accuracy on both the supported customer domain and withheld behaviour, plus normal-task correctness and availability.

6. Challenge the best configuration with longer budgets, new identities, alternate workflows and independently prepared targets before relying on it in a product.

The current benchmark covers the original private pricing domain and two normal quotes. Step 5's complete supported-product clone evaluation and step 6's broad independent challenge remain future work.

## Safety, reproducibility and limits

The experiment used only owned loopback fixtures, generated pricing rules, ephemeral study cookies and fresh browser profiles. Model inference used the configured Codex service and received synthetic observations; the pricing targets themselves ran locally. Agent shell, environment access, external browsing, apps, plugins, memories and inherited Node MCP access were disabled. Raw account/engine events and private reasoning streams are excluded from the public projection. Session values are supplied through REA secret references; header values are not captured. The public record uses relative paths and synthetic identifiers. These are scope and privacy controls on a trusted shared laptop, not an OS/VM security certification or proof that all host software is uncompromised.

The complete repository contains the frozen plan and source, actual REA captures, projected agent/tool transcripts, failed attempts if any, predictor files, target commitments, holdout selections, every score and offline verifiers. Public file hashes and body hashes permit consistency checking. They are not independent attestation. Browser captures retain their incomplete-coverage flags. No production security certification, universal anti-REA claim or whole-product cloning prevention has been established.

Use the reproduction guide and continuation agenda to extend the work. The immediate research priority is independent repeated-agent testing on more complex targets and realistic approval and export paths, while measuring supported-product imitation and customer impact separately.